SECCIÓN 8.4

Manejo de información sensible

Temas de esta sección:

- Tipos de información sensible en un caso SOC
- Principio de need-to-know: qué es y cómo aplicarlo
- Errores comunes de exposición de información
- Canales correctos para cada tipo de dato
- Ejercicio: ¿qué compartirías y con quién?

Datos personales

- Nombres de usuarios
- Correos y contactos
- Credenciales
- Datos de RRHH
- Historial de actividad

Datos del negocio

- Documentos legales
- Información financiera
- Contratos y acuerdos
- Propiedad intelectual
- Datos de clientes

Datos de investigación

- Evidencia forense
- Logs originales
- IOCs confidenciales
- Identidad del sospechoso
- Estado del caso

Todo lo anterior aplica principio de need-to-know: solo quienes necesitan la información para cumplir su función deben tenerla.

Los errores más frecuentes no son intencionales — son el resultado de hábitos descuidados o urgencia mal manejada:

Canal equivocado

Compartir capturas con datos de usuarios en el canal general del equipo en lugar del canal restringido del caso.

Screenshots sin recortar

Adjuntar capturas con credenciales, correos internos o datos personales visibles en documentos o tickets.

Escalamiento excesivo

Incluir a personas que no necesitan la información "por si acaso", violando need-to-know.

Herramientas no aprobadas

Pegar logs o evidencia en herramientas de IA o servicios cloud externos no autorizados por la organización.

Resumen prematuro

Comunicar una hipótesis como confirmada antes de tener evidencia suficiente, generando alarma o acciones incorrectas.

Sin cifrar

Enviar evidencia sensible por canales no cifrados (email simple, chat sin TLS, Whatsapp personal).

8.4 | Canales correctos para cada tipo de dato

Usar el canal correcto no es burocracia — es parte del control de la investigación:

Tipo de dato	Canal correcto	A quién
Evidencia técnica del caso	Canal privado del caso / plataforma SOAR / ticket interno	Solo equipo del caso
IOCs confirmados	Plataforma de Threat Intel / ticket estructurado	Equipo de inteligencia + stakeholders definidos
Datos personales del usuario	Canal cifrado / solo Legal o RRHH cuando corresponde	Necesidad justificada
Estado del incidente	Reporte oficial / canal de management según política	Management + Legal si requiere
Hipótesis de trabajo	Canal del equipo de análisis — nunca externo sin aprobación	Equipo SOC + IR
Capturas / logs crudos	Sistema de evidencia forense / no adjuntar en chats generales	Analistas + IR

8.4 | Ejercicio: ¿qué compartirías y con quién?

Para cada situación, decidí: ¿qué información compartís, a quién y por qué canal?

1

El analista descubre que el usuario comprometido es el CEO

Evidencia: acceso a carpetas no habituales + credential dumping en su endpoint. ¿Qué informás? ¿A quién? ¿Por qué canal? ¿Qué NO hacés?

2

Tenés un IOC (IP de C2) no confirmado aún

La IP apareció en 3 endpoints. Aún sin correlación completa. ¿Lo compartís con todo el equipo? ¿Lo cargás en Threat Intel? ¿Cuándo y cómo?

3

Un colega pide acceso a los logs del caso para "aprender"

Es del mismo SOC pero no está asignado al caso. Los logs contienen datos personales de usuarios. ¿Qué respondés?